

Part 5: WPA2 offline candidate verification

Ethical and authorized use: use only the supplied synthetic metadata or an instructor-created PCAP. Do not capture traffic, deauthenticate clients, disrupt networks, or test third-party credentials.

The password is not transmitted in a WPA2 four-way handshake. Nevertheless, a recorded SSID, AP/STA MAC addresses, ANonce/SNonce, EAPOL bytes, and MIC let a candidate be checked offline:

```
candidate passphrase + SSID -> PBKDF2-HMAC-SHA1 -> PMK
PMK + ordered MACs/nonces -> PRF -> PTK -> KCK
KCK + EAPOL frame -> candidate MIC -> compare with captured MIC
```

Run the explanation and single-candidate checker against `../data/wpa2_capture.json`. Server-side rate limiting cannot observe or slow local guesses after capture. WPA2-Enterprise and WPA3-SAE have different authentication properties and are outside this exercise.

Inspect the synthetic handshake metadata

```
cd /workspace/labs/lab01/part5_wpa2
python3 explain_handshake.py ../data/wpa2_capture.json
```

Expected output lists the synthetic SSID, AP and client MAC addresses, two nonces, and the captured MIC, followed by the PMK -> PTK -> KCK -> MIC chain. The JSON file is calculation metadata created for the course, not captured third-party traffic.

Verify one candidate

The candidate is read with `getpass`, so it is not displayed or stored in shell history:

```
python3 verify_candidate.py ../data/wpa2_capture.json
Candidate:
no match
```

A candidate consistent with the synthetic record prints match; other inputs print no match. Try candidates only from the provided classroom wordlist. The script performs no network or radio operation.

If the instructor supplies `../data/wpa2/lab01-instructor.pcap`, the optional local-only tool demonstration is:

```
aircrack-ng -w ../data/lab01-small.txt ../data/wpa2/lab01-instructor.pcap
```

This optional command works only after the instructor supplies that exact local PCAP. A missing-file error is expected when only the repository placeholder is present. Do not substitute an external capture.

Checkpoint questions

1. Which captured values make candidate verification possible?
2. Why is this classified as offline guessing?
3. Where is the password used even though it never crosses the network?
4. Why can server-side rate limiting not slow this computation?
5. Why should these WPA2-Personal observations not be generalized directly to WPA2-Enterprise or WPA3-SAE?